Vulnerability Assessment Report

DownUnderNewsz Vulnerability Assessment Report

DownUnderNewsz (The Down Under News)
22 Arthur St
Fairfield VIC 3078, Australia

Flinders University
Sturt Road, Bedford Park SA 5042

September 18, 2026

Report Version: 1.0

CONFIDENTIAL

Table of Contents

List of Figures 3

1 Document Control 4

1.1 Team 4

1.2 List of Changes 4

2 Executive Summary 5

2.1 Overview 5

2.2 Identified Vulnerabilities 6

3 Methodology 8

3.1 Objective 8

3.2 Scope 8

3.3 User Accounts and Permissions 9

4 Findings 10

C1: Unauthenticated Jinja-style server-side template injection in search 10

H1: Anonymous FTP allows listing and download of media files 12

M1: www certificate name mismatch 13

M2: Python application server exposed on port 5000 without TLS 14

M3: Session JWT cookie missing Secure and SameSite flags 15

M4: Missing HTTP security headers 16

M5: Public articles API discloses account profile fields 17

M6: Internet-facing SSH allows password authentication 18

5 Disclaimer 19

A Appendix 20

A.1 Static Appendix Section 20

A.2 Finding summary 20

A.3 Methodology and safety limits 20

List of Figures

Figure 1 - Distribution of identified vulnerabilities 7

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Initial authorized vulnerability assessment report	Sep 18, 2026

2 Executive Summary

2.1 Overview

Overview

ClawSec completed an authorized vulnerability assessment of **DownUnderNewsz** (shown on the site as **The Down Under News**), an online-only independent Australian news publication. All work took place on **18 September 2026**, after authorization on the main public website.

The review covered only the owner-approved website, media host, and two server addresses. Eight issues were confirmed: **1 critical, 1 high, 4 medium, and 2 low**. Nothing was added beyond what was verified.

What leadership should know

Fix the search box first. Anyone on the internet can type a crafted search that the site runs as template code instead of plain text. Safe checks showed `{{8*8}}` becoming **64** and `{{7*'7'}}` becoming **7777777**. On typical Flask/Jinja sites this class of bug is used to read secrets and take over the server. Remote code execution was not attempted.

The media server is an open file store. It accepts FTP login as “anonymous” with no password. A visitor can list and download stored files. HTTPS on this host currently fails (HTTP 502), so FTP is an open path to those files.

The website backend is reachable in the clear. Gunicorn answers on port 5000 without TLS, so traffic can skip the nginx HTTPS front door.

Trust in HTTPS and staff privacy is weaker than it should be. The `www` certificate does not match the hostname. Login cookies are missing `Secure` and `SameSite`. The public articles API returns staff emails, admin roles, account-active flags, and user ids with every article.

Lower-priority hardening: the homepage is missing standard browser security headers, and both servers offer SSH password login from the internet. No password guessing was performed.

Recommended order of work

1. Stop rendering search input as a template; show the query as data only and add a test that `{{8*8}}` is displayed literally.
2. Disable anonymous FTP; restore HTTPS so media is served only through the application.
3. Bind the application server to localhost and block port 5000 at the firewall.
4. Reissue the certificate for both hostnames (or redirect `www` before TLS); set `Secure`, `HttpOnly`, and `SameSite` on the session cookie; return only public byline fields from the articles API.
5. Add HSTS and related HTTP headers; restrict SSH to keys and network allowlists.

Coverage and limits

Both in-scope hosts and IPs were scanned. Public site, search, APIs, admin panel, role separation, anonymous FTP, TLS, and session cookies were reviewed. Authenticated CMS tests used owner-provided dummy roles (admin, writer, editor).

Limits: media HTTPS returned 502 on all tested paths, so media testing used FTP and port scans. SSH was not brute-forced. Stored XSS in an unpublished draft was not counted as a confirmed public finding. Amass and Censys were unavailable. `www` TLS could not be verified because of the certificate hostname mismatch.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	9.8	Unauthenticated Jinja-style server-side template injection in search	10
H1	7.5	Anonymous FTP allows listing and download of media files	12
M1	6.8	www certificate name mismatch	13
M2	6.5	Python application server exposed on port 5000 without TLS	14
M3	6.3	Session JWT cookie missing Secure and SameSite flags	15
M4	5.4	Missing HTTP security headers	16
M5	5.3	Public articles API discloses account profile fields	17
M6	4.8	Internet-facing SSH allows password authentication	18

Vulnerability Overview

In the course of this penetration test **1 Critical**, **1 High** and **6 Medium** vulnerabilities were identified:

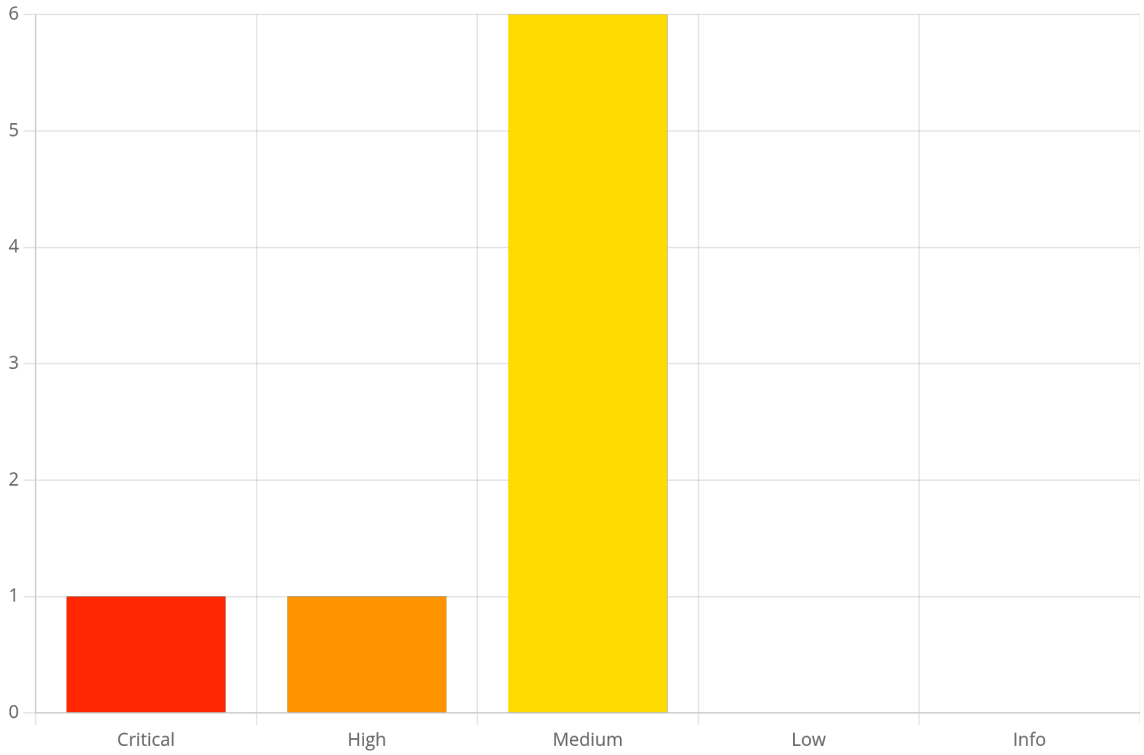


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

In-scope assets (owner-approved)

System	Address	Notes
thedownundernews.online	51.161.130.70	Main public website; authorization host
www.thedownundernews.online	51.161.130.70	Same origin; TLS certificate hostname mismatch
media.thedownundernews.online	51.161.131.195	Media host; HTTPS 502 on tested paths
Web VPS	51.161.130.70	Open ports 22, 80, 443, 5000
Media VPS	51.161.131.195	Open ports 21, 22, 80, 443

Only these two IP addresses were in scope.

Explicitly out of scope

- thedownundernews.it.com (candidate; owner did not include)
- OVH netblocks
- Spaceship / Cloudflare
- Google Fonts
- jsDelivr
- Flinders University

Methodology

Authorized full-scope assessment after header-based authorization on `https://thedownundernews.online/`.

- Asset enumeration, then owner validation of scope
- Fast full-port discovery, then version scans on open ports
- TLS and HTTP header review
- Web and API mapping
- Authenticated CMS testing with owner-provided dummy roles (admin, writer, editor)

Safety limits: no DDoS, brute force, spraying, phishing, malware, destructive actions, or third-party testing. SSTI was proven with arithmetic template expressions only; no RCE payload was sent.

Coverage

Hosts and both IPs were scanned. Public site, search, APIs, admin panel, role separation, anonymous FTP, TLS, and session cookies were reviewed.

Limitations

- media.thedownundernews.online HTTPS returned 502 on all tested paths; media testing used FTP and port scan.
- No password guessing against SSH.
- Stored XSS in an unpublished draft was not counted as a confirmed public finding.
- Amass/Censys unavailable during enumeration.
- www TLS could not be verified because of certificate hostname mismatch.

3.3 User Accounts and Permissions

Owner-provided dummy CMS roles used for authenticated testing:

- admin
- writer
- editor

No live production passwords are included in this report.

4 Findings

C1: Unauthenticated Jinja-style server-side template injection in search	
Score	9.8 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Target	• https://thedownundernews.online/search • http://51.161.130.70:5000/search
References	• CWE-1336 • CWE-94 • OWASP A03:2021 Injection

Overview

Anyone on the internet can send a crafted search query that the website executes as a template, not as plain text. This is the highest-priority issue. Safe checks showed the site computing values from the query; further takeover testing was not performed.

Details

The public search parameter `q` is rendered through a server-side template engine (Jinja2-style) on the HTML search page.

Verified, non-destructive proofs:

- `GET /search?q={{8*8}}` returned title `Search: 64 - The Down Under News` (also reflected in the search input value).
- `GET /search?q={{7*'7'}}` returned a title containing `7777777`, which is the Jinja2 evaluation of that expression.

The same arithmetic evaluation occurred on the Gunicorn service on TCP 5000. `/api/search?q=` did not evaluate templates and is not this issue.

No debugger/traceback was required for confirmation. Remote code execution was not attempted, in line with engagement safety limits. On typical Flask/Jinja deployments this class of bug is used to read secrets and take over the server.

Recommendation

Stop rendering user input as a template. Pass the query into the HTML template as a data variable only, and keep auto-escaping on. Add regression tests that `{{8*8}}` is shown literally. Put a web application firewall rule in place as a temporary shield, then patch the application.

H1: Anonymous FTP allows listing and download of media files	
Score	7.5 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Target	51.161.131.195:21 (media.thedownundernews.online)
References	• CWE-306 • CWE-287 • CWE-552

Overview

The media server accepts FTP logins as “anonymous” with no password. A visitor can list and download files from the media store. HTTPS on this host currently fails (502), so FTP is an open back door to those files.

Details

Port 21 runs vsftpd 3.0.5. Nmap reported anonymous FTP enabled. Confirmed:

- Anonymous login succeeded (`230 Login successful.`).
- Root listing showed hashed objects including `.html`, `.png`, and `.pdf` files.
- Anonymous download of `37550846eae5457d93ddd8e1d2faeaca.html` completed (`226 Transfer complete.`). File contents were not retained.

No upload, delete, or brute force was performed. These filenames match the style of the CMS media library. Combined with the broken HTTPS front end, this exposes stored media without going through the website’s login or access rules.

Recommendation

Disable anonymous FTP. If file transfer is still required, use SFTP/FTPS with named accounts, chroot, and allowlists. Firewall port 21 from the internet. Restore the HTTPS media site so files are served only through the application.

M1: www certificate name mismatch	
Score	6.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N
Target	https://www.thedownundernews.online/ (51.161.130.70)
References	CWE-297

Overview

Browsers that verify HTTPS will warn or refuse `www.thedownundernews.online` because the certificate is only for the name without `www`. Visitors can be tricked more easily, and some clients cannot load the site securely.

Details

DNS for `www.thedownundernews.online` points to 51.161.130.70, the same origin as the apex. The presented certificate CN/SAN is only `thedownundernews.online` (Let's Encrypt, valid 2026-09-16 to 2026-12-15). OpenSSL verify code 62 (hostname mismatch). `http://www.thedownundernews.online/` 301-redirects to `https://www.thedownundernews.online/`, sending users into the broken HTTPS name. Apex HTTPS works.

Recommendation

Reissue the certificate with both `thedownundernews.online` and `www.thedownundernews.online` (or redirect www to apex on HTTP before TLS). Prefer a single canonical hostname.

M2: Python application server exposed on port 5000 without TLS	
Score	6.5 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Target	51.161.130.70:5000 (thedownundernews.online)
References	• CWE-319 • CWE-16

Overview

The public website's backend (Gunicorn) is reachable on port 5000 in cleartext. Attackers can talk to the app while skipping the nginx HTTPS front door.

Details

A full-port probe of 51.161.130.70 found TCP 22, 80, 443, and 5000 open. Service detection identified Gunicorn. `GET http://51.161.130.70:5000/` returned HTTP 200, `Server: gunicorn`, and the same homepage as the public site (Content-Length 23012). The search SSTI also reproduced on this port. Traffic on 5000 is not TLS-protected and does not receive nginx HTTP security controls.

Recommendation

Bind Gunicorn to localhost only (or a private network). Block 5000 at the firewall. Keep nginx as the only public HTTP(S) entry point.

M3: Session JWT cookie missing Secure and SameSite flags	
Score	6.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:L/A:N
Target	https://thedownundernews.online/admin/login
References	• CWE-614 • CWE-1275 • OWASP A05:2021 Security Misconfiguration

Overview

After login, the site stores the session in a cookie that can be sent over unencrypted HTTP and is not restricted to same-site requests. That makes session theft and cross-site request abuse easier.

Details

Successful login to `/admin/login` with an owner-provided dummy account set `access_token_cookie`. Observed flags: `HttpOnly` and `Path=/`. `Secure` was false. `SameSite` was absent. The cookie is a JWT (`alg: HS256`, `typ: JWT`) with claims including `sub`, `type=access`, `iat`, `exp`. No CSRF cookie or form token was observed on admin pages. Port 80 is open, and HSTS is not set, so an SSL-stripping or mixed-content path can leak the token. The JWT secret was not attacked.

Recommendation

Set `Secure; HttpOnly; SameSite=Strict` (or Lax if a weaker trade-off is required) on the session cookie. Enable HSTS. Turn on CSRF protection for cookie-based JWT (for example flask-jwt-extended CSRF cookies) on state-changing requests.

M4: Missing HTTP security headers	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://thedownundernews.online/
References	• CWE-693 • OWASP A05:2021 Security Misconfiguration

Overview

The live homepage does not send standard browser-defense headers. This makes clickjacking, MIME sniffing, and protocol downgrade easier.

Details

`GET https://thedownundernews.online/` returned 200 from nginx with no `Content-Security-Policy`, `Strict-Transport-Security`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, or `Permissions-Policy`. No session cookie is set on the public homepage; the header gap still applies site-wide, including admin after login.

Recommendation

Add HSTS, CSP (start report-only if needed), `X-Frame-Options: DENY` or CSP `frame-ancestors`, `X-Content-Type-Options: nosniff`, and a strict Referrer-Policy on nginx.

M5: Public articles API discloses account profile fields	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	https://thedownundernews.online/api/articles
References	• CWE-200 • CWE-359

Overview

The public news API returns staff usernames, roles, account-active flags, user ids, and email addresses with every article. That is more than a public byline needs and helps attackers target staff accounts.

Details

Unauthenticated `GET /api/articles` returned JSON articles whose `author` objects included `id`, `username`, `email` (domain thedownundernews.it.com), `first_name`, `last_name`, `role` (including `admin`), `is_active`, and `created_at`. Article bodies were not required for this finding. CORS is locked to the apex origin, but the JSON is still readable by any direct client.

Recommendation

Return only public byline fields (display name). Keep email, role, is_active, and internal ids off unauthenticated APIs.

M6: Internet-facing SSH allows password authentication	
Score	4.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Target	• 51.161.130.70:22 • 51.161.131.195:22
References	CWE-308

Overview

Both servers offer SSH login with a password from the internet. Password SSH is a common brute-force target. No password guessing was performed.

Details

OpenSSH 10.0p2 Debian 7+deb13u4 on both in-scope IPs advertises authentication methods `publickey` and `password`. Algorithms observed were modern; no weak ciphers were flagged. This is a hardening issue, not proof of a compromised account.

Recommendation

Disable password authentication, allow keys only, restrict SSH by firewall/VPN, and keep fail2ban or equivalent in place.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Finding summary

Eight confirmed findings. No findings were added or dropped.

Severity	Count
Critical	1
High	1
Medium	4
Low	2

1. Unauthenticated Jinja-style server-side template injection in search (Critical)
2. Anonymous FTP allows listing and download of media files (High)
3. Python application server exposed on port 5000 without TLS (Medium)
4. Session JWT cookie missing Secure and SameSite flags (Medium)
5. www certificate name mismatch (Medium)
6. Public articles API discloses account profile fields (Medium)
7. Missing HTTP security headers (Low)
8. Internet-facing SSH allows password authentication (Low)

A.3 Methodology and safety limits

Work followed the authorized engagement rules.

Included: enumeration of owner-approved assets; fast full-port discovery then version scans; TLS and header review; web and API mapping; authenticated CMS testing with dummy admin, writer, and editor roles; anonymous FTP confirmation; session-cookie review.

Not performed: DDoS; brute force; password spraying; phishing; malware; destructive actions; third-party testing; SSH password guessing; RCE payloads against the search SSTI (arithmetic proofs only).

Services observed on in-scope hosts (from this assessment): web VPS 22/80/443/5000; media VPS 21/22/80/443. Application stack notes from evidence: nginx front end, Gunicorn on port 5000, vsftpd 3.0.5 on the media host, OpenSSH 10.0p2 on both IPs.